Menlo Inception Idea One-Pager: Vexen — the permission layer for AI agents

STAGE **LIVE, PRE-REVENUE** USERS **5,000+ IN 2 MONTHS** TEAM **SOLO FOUNDER** CAPITAL RAISED **NONE** LAUNCHED **JULY 2026**

Why Now Trends creating a ripe environment	• Agents only got **hands** in the last 18 months — tool use, MCP, computer use, agentic checkout — so the blast radius moved from wrong text to a wrong wire transfer. • Frameworks shipped **capability and skipped control**: an agent's limits live in its prompt, which is a suggestion, not a permission. • Accountability is arriving from outside: EU AI Act duties on human oversight and traceability; auditors and insurers now ask "who approved this action?" and there is no artefact to hand them. • Every prior computing era grew a permission layer (RACF → Active Directory → cloud IAM → Okta). **Agents have none, and the conventions are being set right now.**
Needs / Pain Points Acute problems solved	• **No external check before the action.** Nothing outside the agent verifies the limit, and nothing halts the side effect. • **No approval primitive.** Hand-rolled approvals are replayable and amount-escalatable — worse than none, since a signed-looking record claims a human agreed. • **No answer to "who allowed this?"** Evidence is scattered across model traces, vendor dashboards and app logs; reconstruction takes hours. • **Result:** teams keep agents read-only and forfeit the ROI, or hand over a real key and absorb a tail risk they cannot cap, price or explain.
Target Customers Who has the pain	• **Today:** developers and small ops teams running purchasing, refund, payout, invoice and support agents — e-commerce and retail ops, fintech, health, dev-tooling teams. • **User ≠ buyer.** The engineer integrates it; the person who answers for the blast radius signs (eng lead, head of ops, finance lead, CISO). Existing tools serve only the first persona. • **Next:** agent platforms and vertical AI vendors that must offer permissions and approvals to their own customers, then regulated buyers in financial services, healthcare and government.
North Star Ultimate solution & vision	• One question answered continuously, everywhere: **what is this non-human actor allowed to do, right now, up to what magnitude, and who signed off?** • Three steps: (1) the enforcement layer teams choose; (2) a **credential broker** issuing short-lived, scoped, single-purpose credentials so an agent physically cannot exceed its authority rather than being asked not to; (3) a **portable, verifiable statement of bounded authority** that travels between organisations — the missing primitive for agent-to-agent commerce, and for agent insurance. • Endgame: an **open standard** for agent authority, Vexen as reference implementation. Identity got OAuth, payments got card-network rules; agent authority has nothing.
Competitive Landscape Market dynamics	• **Real incumbent:** hand-rolled if-statements and internal approval scripts. Free, ubiquitous, and usually subtly wrong. • **Observability** (LangSmith, Langfuse, Braintrust): records what happened, cannot block. **Guardrails** (Guardrails AI, NeMo): filter text, not actions. **Policy engines** (OPA, Cedar): powerful but developer-only, with no approvals, audit trail or non-technical UI. **Framework HITL:** pauses everything rather than only what matters. • **Category is unowned:** no standard vocabulary, no pricing norm, no analyst quadrant. Plausible entrants: Okta/Auth0 from identity, Stripe from payments, and the agent frameworks bundling a "good enough" feature.
Gap / Value Proposition How we differentiate	• **Enforcement on the write path, not observation on the read path.** Removing Vexen means accepting an ungoverned system, and permission layers are almost never removed. • **Deterministic by design:** 13-step default-deny engine, no I/O and no model anywhere in the enforcement path, so the same request always returns the same answer and the trace is the explanation. • **The invariants competitors get wrong:** approvals single-use, TTL-bound, atomically claimed and scope-bound to permission + resource + amount to the cent; email actions POST-only and signed, so a link scanner cannot approve a $40,000 purchase; hash-verified audit; fail-closed SDK. • **Serves both personas:** one decorator for the engineer; plain-English rules and two-tap phone approval, no login, for the accountable human.
Market Size Where we play, how big	• Metered **per decision, not per seat**, so revenue scales with a customer's automation rather than their headcount — the rare software line item that grows as headcount falls. • **Bottom-up SAM:** ~150k companies running action-taking agents by 2028 × ~$20k average annual spend ≈ **$3B**; a nearer-term 50k × $20k ≈ **$1B**. • **Comparables:** IAM software >$20B and growing; Okta alone ~$2.6B revenue. Agent authority is the same shape of layer, one level down, with more actions per customer than employees.
MVPs Initial versions	• **Already live** (5,000+ users, built solo in 2 months, no paid acquisition): decision API returning ALLOW / BLOCK / APPROVAL_REQUIRED with reason code and trace; 67 business-language permissions across 18 categories; plain-English rule authoring (model writes rules, never enforces); scope-bound single-use approvals; two-tap phone approval; hash-verified audit; fail-closed Python SDK; 10,639 configuration templates; 4-role RBAC. **Verified: 55/55 end-to-end checks, plus an independent 110/110 backend pass.** • **Next 6–12 months:** credential broker; TypeScript SDK, MCP gateway and native framework guards; published external pentest, SOC 2 Type I, SSO/SCIM; 10 design partners with agents in production; v0.1 of the open authority spec.
Business Models Monetization & GTM cost	• **Freemium to usage-metered:** free decision allowance → self-serve $99–$999/mo by decision volume (~$7k ACV) → mid-market $12–25k → enterprise $50–100k, gated on SSO, SCIM, retention, pentest, SOC 2 and the broker. • **Path:** ~$250k ARR by month 6; $1.2–1.5M by month 12. $10M at month 24 requires 100 enterprise @ $60k + 250 mid-market @ $14k + 250 self-serve @ $2.4k. **Base case $3–5M** unless platform embeds carry distribution. • **GTM cost is low and proven:** content-led, no paid acquisition — 100,000+ users across five prior products. Spend is two hires (founding engineer, first GTM) plus ~$60–80k for SOC 2 and a published pentest.
Key Risks / Open Qs Needs further testing	• **No forcing function yet.** No job title owns "agent authority". Engineers feel a permission layer as roadmap friction, the exposed executive does not know the exposure exists, so it loses to "we'll add an if-statement" until an incident or auditor intervenes. • **Broker unbuilt.** Today an agent can route around Vexen, so a rigorous buyer calls it a convention rather than a control — which is why it is the next thing built. • **Open questions:** does **decisions per account** compound 30–40% QoQ (the whole expansion thesis)? Can a solo-founded vendor pass enterprise security review by month 12? Open standard vs. proprietary — what sequencing maximises adoption without commoditising the company? • **Honest gaps:** no revenue, Python-only SDK, no SOC 2, and a solo founder who has never sold security through procurement. The first two hires target exactly those.